



Data Governance & Provenance

Afeena Gafoor
Spring 2026

▀ Roadmap



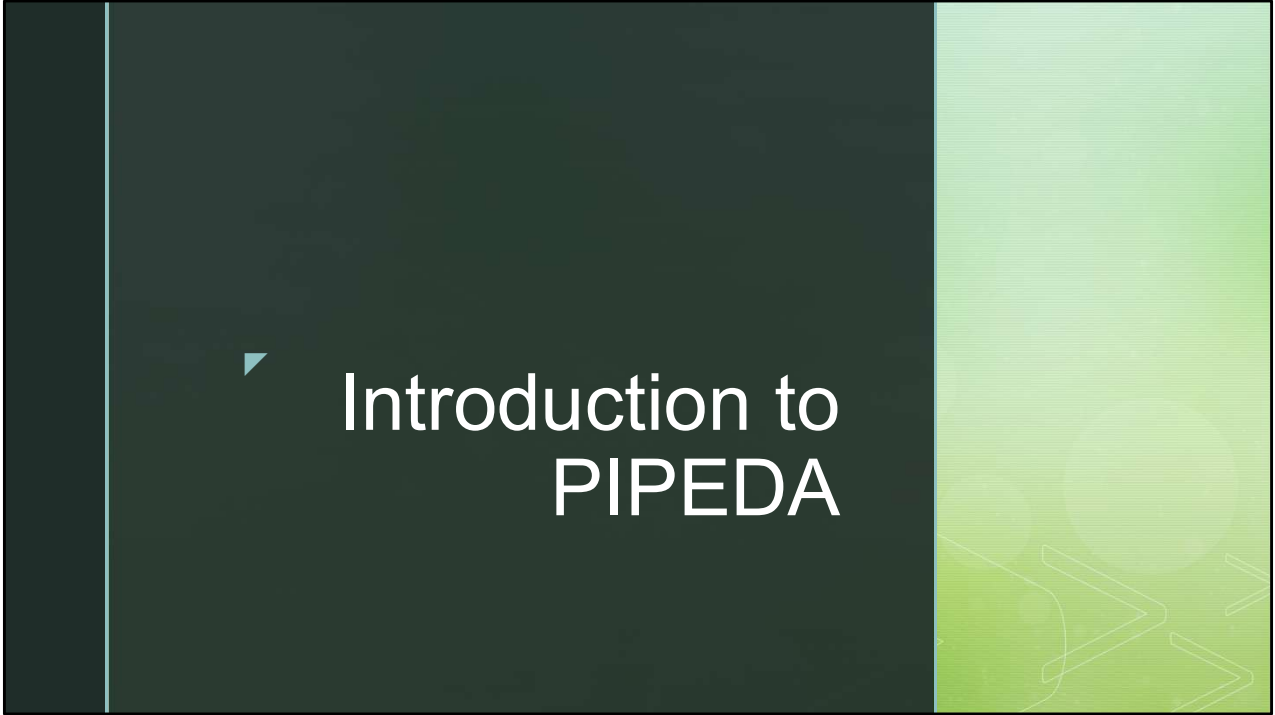
Introduction to PIPEDA



PIPEDA Principles



Questions & Answers



Introduction to PIPEDA

Good afternoon everyone.

Today, I'll be introducing PIPEDA, which stands for the **Personal Information Protection and Electronic Documents Act**.

PIPEDA is Canada's main federal private-sector privacy law. It regulates how organizations collect, use, and disclose personal information during commercial activities.

Privacy law is a rapidly evolving area, especially as technology, artificial intelligence, cloud computing, and data sharing continue to grow.

Although Canada is expected to eventually modernize or replace parts of PIPEDA, the principles behind the law remain extremely important because they form the foundation of privacy protection in Canada.

In this presentation, we'll first look at the Canadian privacy law landscape, then discuss what PIPEDA is, key concepts within the law, and finally the 10 privacy principles that organizations are expected to follow.

Canada's Privacy Law Landscape

- Canada has multiple overlapping privacy laws
- Federal and Provincial jurisdiction
- Public sector vs. private sector privacy laws
- “Mosaic” of privacy legislation

To understand PIPEDA, it's important to first understand the Canadian privacy law landscape.

Canada does not have just one privacy law. Instead, we have a combination- or what many describe as a mosaic- of federal and provincial privacy laws.

This exists because Canada is a federal system with both federal and provincial governments sharing legislative powers under the Constitution.

Generally:

- Provinces regulate privacy as part of property and civil rights,
- while the federal government regulates trade and commerce and federally regulated industries.

As a result, different privacy laws apply depending on:

- the province,
- the sector,
- and the type of organization involved.

For example:

- public sector organizations are covered by public-sector privacy laws,
- health-care organizations may be covered by specialized health privacy legislation,
- and private businesses are generally covered either by PIPEDA or provincial private-sector privacy laws.

This creates overlapping jurisdiction, but in practice the laws generally work together.

What is PIPEDA

- Federal private- sector privacy law
- Applies to commercial activities
- Based on CSA Model Code
- Came fully into force in 2004

PIPEDA is Canada's federal private-sector privacy law.

Its full name is the Personal Information Protection and Electronic Documents Act.

The law applies primarily to the collection, use, and disclosure of personal information during commercial activities.

PIPEDA was developed in the late 1990s and was heavily based on something called the Canadian Standards Association Model Code for the Protection of Personal Information.

Instead of creating an entirely new framework, the federal government adopted this existing privacy code and built the law around its 10 privacy principles.

PIPEDA officially came fully into effect in 2004.

Today, some provinces- including Quebec, Alberta, and British Columbia- have their own private-sector privacy laws that are considered substantially similar to

PIPEDA.

In those provinces, the provincial law often applies instead of the federal law for many business activities.

Even though PIPEDA is over 20 years old, it still plays a central role in Canadian privacy law and continues to influence how organizations manage personal information.

Key Concepts Under PIPEDA

- Commercial activity
- Personal information
- Reasonableness requirement
- Consent-based framework

Before discussing the 10 principles, there are a few important concepts within PIPEDA that help explain how the law works.

The first key concept is commercial activity.

PIPEDA applies when organizations collect, use, or disclose personal information during commercial activities.

Another important concept is personal information.

Under PIPEDA, personal information means any information about an identifiable individual.

This definition is extremely broad and includes things like:

- names,
- addresses,
- financial information,
- health records,
- photographs,

- biometric data,
- and online identifiers.

If a person can reasonably be identified from the information, it will likely be considered personal information under the law.

PIPEDA is also built around consent.

In most situations, organizations need an individual's knowledge and consent before collecting, using, or disclosing their personal information.

Finally, PIPEDA includes a baseline reasonableness requirement.

Even if an organization obtains consent, it can only collect, use, or disclose information for purposes that a reasonable person would consider appropriate in the circumstances.

This acts as an important safeguard against unreasonable or excessive data practices.

10 Principles of PIPEDA

- Accountability
- Identifying Purpose
- Consent
- Limiting Collection
- Limiting Use, Disclosure & Retention
- Accuracy
- Safeguards
- Openness
- Individual Access
- Challenging Compliance

At the core of PIPEDA are 10 privacy principles taken from the Canadian Standards Association Model Code.

These principles form the foundation of how organizations are expected to manage personal information in Canada.

The principles focus on:

- accountability,
- transparency,
- consent,
- accuracy,
- security,
- and individual rights.

Although each principle is separate, they are highly interconnected.

For example:

- organizations must first identify their purposes before they can obtain meaningful consent,

- and the identified purposes later determine what information can be collected, how it can be used, and how long it can be retained.

The 10 principles together create a framework designed to balance business operations with the protection of individual privacy rights.

The rest of this presentation will walk through each of these principles and explain how they operate under PIPEDA.

■ Principle 1 - Accountability

An organization is responsible for personal information under its control. It must appoint someone to be accountable for its compliance with these fair information principle

The first principle of PIPEDA is Accountability.

This principle says that organizations are responsible for any personal information under their control.

Under PIPEDA, organizations must appoint a person (often called a Privacy Officer) who is responsible for ensuring the organization follows privacy laws and complies with all ten PIPEDA principles.

An important point is that the Privacy Officer is **not** personally liable for privacy breaches. Instead, they act as the internal leader responsible for privacy compliance, customer concerns, and communication with regulators. Accountability also means that organizations remain responsible for personal information even when they transfer it to a third party for processing.

For example, if a company hires a cloud storage provider or payroll company to manage customer information, the original organization is still legally responsible for protecting that data.

This introduces an important distinction between a transfer and a disclosure.

A transfer happens when information is shared with a service provider that is only processing the information on behalf of the original organization. In this case, consent is generally not required because the original organization still controls the information.

A disclosure is different. A disclosure occurs when information is shared with another organization so that organization can use the information for its own purposes. In that case, consent is required.

This principle is important because it establishes that organizations cannot avoid responsibility simply by outsourcing data handling to another company. Accountability remains with the organization that originally collected the information.

■ Principle 2 - Identifying Purposes

The purposes for which personal information is collected must be identified by the organisation at or before the time the information is collected

The second principle of PIPEDA is Identifying Purposes, and this principle is closely connected to Principle 3 consent.

This principle says that organizations must identify the reasons why they are collecting personal information at or before the time the information is collected.

There are really two parts to this principle.

First, the organization must internally determine and document exactly why it is collecting the information.

Second, those purposes must be clearly communicated to the individual before the information is collected or used.

For example, if a company asks for a customer's email address, the company should explain whether the email will be used for account verification, customer service, marketing, or all of those purposes.

One important point is that simply posting a privacy policy on a website is usually **not enough**.

PIPEDA expects organizations to communicate purposes in a way that

individuals can reasonably understand. This means the explanation should be clear, accessible, and provided at the appropriate time.

This principle also places responsibility on employees who collect information. They should be able to explain to individuals why the information is being collected and how it will be used.

Identifying purposes is critical because it creates transparency and sets boundaries on how organizations may use personal information.

It also directly supports Principle 3, Consent- because meaningful consent is only possible if individuals actually understand what they are agreeing to.

Principle 3 - Consent

The knowledge and consent of the individual are required for the collection use or disclosure of person information, except where inappropriate

The third principle is Consent, which is considered one of the **core foundations** of PIPEDA.

This principle states that organizations must obtain an individual's knowledge and consent for the collection, use, or disclosure of personal information, unless a specific legal exception applies.

In Canada, consent is the primary legal basis for handling personal information in the private sector.

However, consent under PIPEDA must be informed consent.

This means individuals must understand:

- what information is being collected
- why it is being collected
- how it will be used
- and the possible consequences of agreeing.

This is why Principle 2 (Identifying Purposes) is so important. Without clearly

identifying purposes, consent cannot truly be informed.

PIPEDA also recognizes that not all personal information is equally sensitive.

For less sensitive information, consent may sometimes be implied. For example, when a customer provides an address for product delivery, it is reasonable to assume consent for that purpose.

However, for sensitive information, such as medical or financial data , organizations are expected to obtain express consent, usually through an **opt-in process** or written agreement.

Another **important rule** is that organizations cannot require individuals to consent to unnecessary data collection.

In other words, companies should only collect information that is necessary for legitimate business purposes.

PIPEDA also gives individuals the right to withdraw consent at any time. However, organizations must explain the consequences of withdrawing consent.

For example, if a customer withdraws consent for the use of information necessary to provide a service, the organization may no longer be able to provide that service.

Overall, this principle emphasizes individual control over personal information and reinforces the importance of transparency and trust between organizations and consumers.

▀ Principle 4 - Limiting Collection

The collection of personal information must be limited to that which is needed for the purposes identified by the organization.
Information must be collected by fair and lawful means.

Now we move into Principle 4, which is called Limiting Collection.

This principle says that organizations can only collect personal information that is necessary for the purposes they identified earlier under Principle 2.

In simple terms, companies cannot collect extra information “just in case” they may want it later. The information collected must directly relate to a legitimate business purpose.

For example, if a business only needs an email address to send updates to a customer, it should not also request unrelated sensitive information like medical history or a social insurance number.

The principle also says that information must be collected by fair and lawful means.

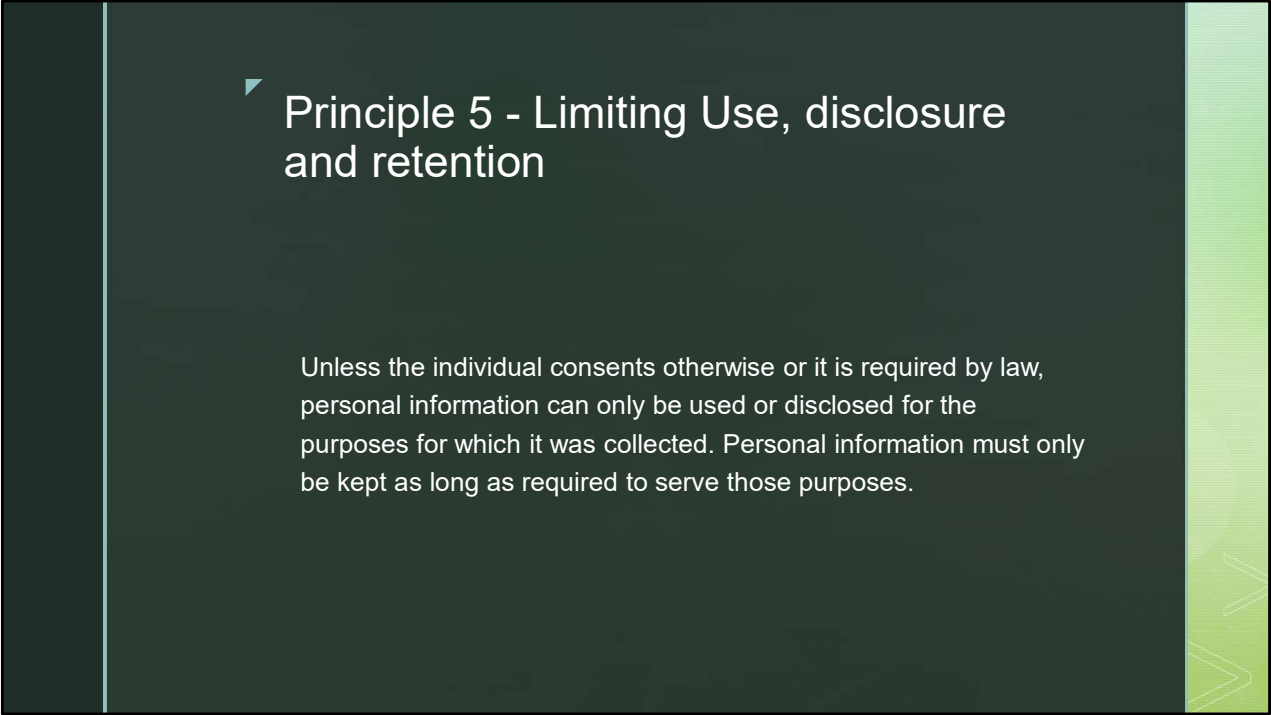
This means organizations cannot use deception, misleading tactics, or hidden methods to gather personal information.

What’s important here is how this principle connects back to Principle 2-

Identifying Purposes.

The purposes identified earlier act as guard rails. They determine what information an organization is allowed to collect and prevent unnecessary data collection.

Overall, Principle 4 is about data minimization, collecting only what is truly needed and nothing more.



Principle 5 - Limiting Use, disclosure and retention

Unless the individual consents otherwise or it is required by law, personal information can only be used or disclosed for the purposes for which it was collected. Personal information must only be kept as long as required to serve those purposes.

Principle 5 is called Limiting Use, Disclosure, and Retention.

This principle says that organizations may only use or disclose personal information for the purposes that were originally identified to the individual.

If the organization later wants to use the information for a completely different purpose, it must inform the individual of the new purpose and obtain new consent.

So again, this principle ties directly back to Principles 2 and 3:

- Principle 2 identifies the purposes,
- Principle 3 obtains consent,
- and Principle 5 limits how the information can be used afterward.

This principle also introduces the concept of retention limits.

Organizations should only keep personal information for as long as necessary to fulfill the identified purposes.

Once the information is no longer needed, it should either be securely destroyed or properly anonymized.

This is important because keeping unnecessary personal information increases privacy and security risks, especially in the event of a data breach.

Although PIPEDA does not explicitly require a written retention policy, organizations should have one in practice so they know:

- why information was collected,
- how long it should be kept,
- and when it should be disposed of securely.

Overall, Principle 5 ensures organizations do not misuse personal information or keep it indefinitely without justification.

▀ Principle 6 - Accuracy

Personal information must be as accurate, complete, and up-to-date as possible in order to properly satisfy the purposes for which it is to be used.

Principle 6 is the Accuracy Principle.

This principle says that personal information must be as accurate, complete, and up to date as necessary for the purposes for which it is being used.

Again, the key phrase is “necessary for the purposes”.

This principle becomes especially important when organizations use information to make decisions about individuals.

For example, inaccurate information in a credit report, employment file, or banking application could negatively affect someone’s opportunities or reputation.

Organizations therefore have a responsibility to make sure the information they rely on is sufficiently accurate for the decision being made.

However, PIPEDA does not require organizations to constantly update every piece of information they hold.

The level of accuracy required depends on:

- how the information is being used,
- and the potential consequences for the individual.

Overall, Principle 6 helps ensure fairness by reducing the risk of decisions being made using outdated or incorrect personal information.

▀ Principle 7 - Safeguards

Personal information must be protected by appropriate security relative to the sensitivity of the information.

Principle 7 is called Safeguards, and it is one of the most important principles under PIPEDA.

This principle says that personal information must be protected using security safeguards appropriate to the sensitivity of the information.

PIPEDA specifically says organizations must protect personal information against threats such as:

- loss,
- theft,
- unauthorized access,
- unauthorized disclosure,
- copying,
- use,
- or modification.

Importantly, this protection applies regardless of the format of the information-whether it is stored digitally, on paper, or in cloud systems.

One of the most important aspects of this principle is that it is principles-based rather than overly prescriptive.

PIPEDA does not provide a fixed checklist of exact security measures organizations must use.

Instead, organizations are expected to implement safeguards that are reasonable and appropriate based on:

- the sensitivity of the information,
- the level of risk,
- and current technological standards.

For example, highly sensitive information like health or financial records would require much stronger protections than a basic email subscription list.

Another key point is that what counts as “reasonable safeguards” changes over time as technology evolves.

The security expectations organizations face today are much higher than when PIPEDA first became law in 2001.

At the same time, PIPEDA does not require perfection.

Organizations are expected to take reasonable steps to protect personal information, but they are not expected to eliminate every possible risk.

Overall, Principle 7 emphasizes that protecting personal information is an ongoing responsibility that must evolve alongside technology and emerging threats.

▀ Principle 8 - Openness

An organization must make detailed information about its policies and practices relating to the management of personal information publicly and readily available.

Principle 8 is called Openness.

This principle says that organizations must make information about their privacy policies and practices readily available to individuals.

In simple terms, organizations need to be transparent about how they manage personal information.

This is where privacy policies become important.

Unlike Principle 2, where organizations identify purposes in order to obtain consent, Principle 8 is more about openness and transparency overall.

A privacy policy should clearly explain:

- what personal information the organization collects,
- how it is used,
- how it may be disclosed,
- and what privacy rights individuals have.

The organization must also provide contact information for the Privacy Officer or the person responsible for privacy compliance.

Individuals should also be told how they can exercise their access rights under PIPEDA.

Another important requirement is that organizations should explain whether personal information is shared with affiliates, related companies, or third-party organizations.

Today, organizations are also increasingly expected to explain whether personal information may be stored, transferred, or accessed outside of Canada.

Although this is not explicitly written in PIPEDA itself, the Privacy Commissioner of Canada considers it a best practice, and provinces like Alberta and Quebec actually make these disclosures mandatory.

Overall, Principle 8 is about building trust through transparency and making privacy practices understandable and accessible to the public.

■ Principle 9 - Individual Access

Upon request, an individual must be informed of the existence, use, and disclosure of their personal information and be given access to that information. An individual shall be able to challenge the accuracy and completeness of the information and have it amended as appropriate.

Principle 9 is called Individual Access.

This principle gives individuals the right to know whether an organization has their personal information, how it is being used, and whether it has been disclosed to others.

Upon request, organizations must provide individuals with access to their personal information.

This is often called a data subject access right.

An important part of this principle is that individuals also have the right to challenge the accuracy or completeness of the information and request corrections if necessary.

For example, if a company has outdated or incorrect information about a customer, the individual has the right to ask for that information to be corrected.

Organizations are generally required to respond to these requests within 30 days.

They must also explain to the individual:

- how the information has been used,
- and to whom the information may have been disclosed.

This means organizations need to maintain records about their handling of personal information.

Another important point is that access should usually be provided at little or no cost to the individual.

The information also needs to be understandable. If technical terms or abbreviations are used, organizations may need to explain them clearly.

However, there are some limits to this access right.

Organizations may refuse access in certain situations involving:

- confidential business information,
- another person's personal information,
- or information protected by legal privilege.

Overall, Principle 9 reinforces the idea that individuals should have visibility and control over information held about them.

■ Principle 10 - Challenging Compliance

An individual shall be able to challenge an organization's compliance with the above principles. Their challenge should be addressed to the person accountable for the organization's compliance with PIPEDA, usually their Chief Privacy Officer.

The final principle of PIPEDA is Principle 10, called Challenging Compliance.

This principle says that individuals must be able to challenge an organization's compliance with the PIPEDA principles.

Complaints or concerns should first be directed to the person responsible for privacy compliance within the organization- usually the Privacy Officer identified under Principle 1, Accountability.

This principle is really based on common sense.

Organizations should have an opportunity to hear concerns, investigate complaints, and attempt to resolve problems before the matter escalates to regulators or legal proceedings.

As a result, organizations are expected to have clear procedures in place for:

- receiving complaints,
- investigating concerns,
- responding appropriately,
- and correcting any issues that are identified.

Organizations must also inform individuals that they have the right to escalate complaints to the appropriate privacy regulator if they are not satisfied with the organization's response.

This principle effectively closes the loop on the entire PIPEDA framework.

It reinforces accountability and ensures organizations remain responsible not only for collecting and protecting personal information, but also for responding when individuals believe their privacy rights have not been respected.

Overall, Principle 10 emphasizes trust, accountability, and access to remedies within the Canadian privacy system.

Conclusion

- PIPEDA is Canada's federal private-sector privacy law
- Built around 10 interconnected privacy principles
- Focuses on accountability, consent, transparency, and safeguards
- Balances business needs with individual privacy rights
- Privacy law continues to evolve with technology